

TLP:CLEAR

Фишинг через скомпрометированный аккаунт PSL

Lovable.app как landing-площадка, домен .ru как credential harvester

Phishing | Lovable.app | Compromised mailbox | M365 | PSL.eu

Параметр	Значение
Дата инцидента	15 апреля 2026, 16:27 UTC
Дата анализа	3 мая 2026
Классификация	TLP:CLEAR
Уровень угрозы	СРЕДНИЙ
Тип	Phishing / Credential harvesting (двухступенчатый)
Тема письма	2026 Amend Proposal YF-W-SW89537
Отправитель	aissata-keltoum.drame@psl.eu (скомпрометирован)
Тенант M365	4f8fd695-b3b5-4082-8005-610e9453e6d0 (Université PSL)
Landing URL	hxxps://amendment-gateway[.]lovable[.]app/
Финальный URL	hxxps://dotiojea[.]ru/ojEyxTnj@JqGnH/
Статус финала	DNS-зона удалена (NXDOMAIN sentinel) на момент анализа

1. Краткое заключение

Зафиксировано целевое фишинговое письмо, отправленное 15 апреля 2026 года с подлинного аккаунта Microsoft 365 в тенанте Université Paris Sciences & Lettres (PSL, Франция). Все механизмы аутентификации (DKIM, SPF, DMARC) проходят корректно для домена psl.eu — это не подмена отправителя, а сквозная отправка с захваченного почтового ящика сотрудницы PSL.

Атака двухступенчатая: письмо ведёт на специально созданную страницу-приманку на платформе Lovable.app (AI-сборщик одностраничных сайтов с бесплатным wildcard-HTTPS), а единственная кнопка «View Proposal» на этой странице перенаправляет жертву на финальный URL в RU-зоне — dotiojea.ru, классический credential harvester с уникальным per-victim токеном в пути.

На момент анализа финальный домен dotiojea.ru уже не отвечает: DNSPod (Tencent), на чьих NS-серверах он делегирован, выставил sentinel-SOA «nxdomainadmin@dnspod.com», что соответствует удалению зоны после жалоб либо самим оператором кампании. Приземная страница на Lovable.app остаётся доступной.

2. Письмо-приманка

2.1. Заголовки и аутентификация

Письмо отправлено через настоящий outbound-сервер Microsoft 365 во французском регионе (PR0P264CU014.outbound.protection.outlook.com, IPv6 2a01:111:f403:c20a::4). Внутренний путь — PASP264MB5677.FRAPH264.PROD.OUTLOOK.COM → PR0P264MB3096.FRAPH264.PROD.OUTLOOK.COM, что указывает на тенант, расположенный во French datacenter region.

- DKIM: pass (header.i=@psl.eu, selector2, b=ZzQXrxKa)
- SPF: pass (smtp.mailfrom=psl.eu, IP 2a01:111:f403:c20a::4)
- DMARC: pass (p=NONE, sp=NONE — политика домена слабая)
- X-MS-Exchange-CrossTenant-id: 4f8fd695-b3b5-4082-8005-610e9453e6d0 — идентификатор тенанта PSL

2.2. Социальная инженерия

Письмо имитирует деловой follow-up к ранее отправленному запросу на подпись документа. Текст короткий, давит на срочность и неполучение ответа.

- «I wanted to kindly follow up to see if you had a chance to review my last email. I'm still awaiting your assigned signature.»
- Подпись: настоящая подпись сотрудницы PSL (Drame Aïssata, Assistante pédagogique 1re année, Collège Sciences, Humanités et Société, Université PSL)
- Тема содержит фейковый ID-номер («2026 Amend Proposal YF-W-SW89537») — повышает доверие и затрудняет дедупликацию по subject
- Поле From и To совпадают (отправка «себе»), реальные получатели в BCC — классическая массовая рассылка

3. Этап 1 — страница-приманка на Lovable.app

Кнопка «Access File» в письме обёрнута в Google-redirect (www.google.com/url?q=...), но финальный таргет — hxxps://amendment-gateway.lovable.app/, страница на платформе Lovable (lovable.dev) — AI no-code сборщик одностраничных сайтов. Платформа автоматически выдаёт каждому проекту субдомен на lovable.app, бесплатный TLS-сертификат и Cloudflare-фронт.

3.1. Технические свойства landing-страницы

Параметр	Значение
URL	hxxps://amendment-gateway[.]lovable[.]app/
Платформа	Lovable.dev (AI-сборщик одностраничных приложений)
Lovable project ID	bb952617-8387-4712-a353-768d866d428a
TLS	wildcard *.lovable.app, Google Trust Services WE1, 2026-04-16 → 2026-07-15
Front	Cloudflare AS13335 (CF-RAY POP WAW)
IP A	185[.]41[.]148[.]1, 185[.]41[.]148[.]2
IP AAAA	2a07:8240::1, 2a07:8240::2
Тип	React SPA, единственный CTA-href «View Proposal»
HTML SHA-256	b5fc2252242c74aeb43bce9bc733483a8c79a6792b4eae578ae6c81d570260b7
JS bundle SHA-256	6462db810635dcd49271a491e49af9b481b8acc13be3562341abda7b377200b8

На самой странице нет форм для ввода учётных данных. Это «проходная» — единственная цель landing-уровня в том, чтобы предоставить атакующему «чистый» домен с доверенным TLS, который не блокируется большинством корпоративных URL-фильтров и который пройдет минимальную проверку получателя.

3.2. Систематический abuse платформы Lovable.app

Lovable.app как платформа активно используется для размещения phishing landing-страниц с конца 2025 года. По данным urlscan.io, на домене lovable.app зафиксировано более 230 публичных сканов с тегом «phishing». Подтверждённые соседние кампании, использующие тот же паттерн (Lovable + free-host final hop):

Поддомен	Дата	Бренд / тема	Финальный hop
update-start-hub.lovable.app	2026-04-16	AT&T account update	lisacarswell01.wixsite.com
bet-match-sim.lovable.app	2026-04-10	Спортивный беттинг / fraud	lovable self
betinmatch.fr	2026-04-10	Redirect → bet-match-sim	—
punchonsol.lovable.app	2026-02-22	Solana crypto-drainer	—
kamikadigitalbrand.lova	2025-11-13	Brand impersonation	—

ble.app

4. Этап 2 — финальная цель dotiojea.ru

В JS-бандле landing-страницы захардкожен один внешний href —

hxxps://dotiojea[.]ru/ojEyxTnj@JqGnH/. Это финальная цель кампании, на которой по шаблону должна находиться форма перехвата учётных данных (M365 / DocuSign / Adobe Sign и т.п.).

4.1. Регистрационные данные домена

Параметр	Значение
Домен	dotiojea[.]ru
Дата регистрации	2026-03-24 (за 22 дня до рассылки)
Регистратор	R01-RU (R01 Holding LLC, RU)
Регистрант	Private Person
Статус	REGISTERED, DELEGATED, UNVERIFIED
Срок оплаты	2027-03-24
NS (TLD-уровень)	a.dnspod.com, c.dnspod.com (Tencent DNSPod)
SOA на момент анализа	f1g1ns1.dnspod.net / nxdomainadmin@dnspod.com
A / AAAA / MX	— (зона удалена после жалоб)

4.2. Per-victim токены и масштаб кампании

Структура URL финальной цели — hxxps://dotiojea[.]ru/{token}/, где {token} — уникальный для каждого получателя. На текущий момент известны два токена:

- /ojEyxTnj@JqGnH/ — токен из проанализированного письма (получатель admin@pytkam.net)
- /z58!zTjKI/ — токен из публичного urlscan.io от 2026-04-22 (другая жертва, через неделю)

Использование per-victim токенов — стандартный приём современных AiTM-китов (EvilProxu, Tusoon, Mamba 2FA, Caffeine): индивидуальный URL не выдаётся sandbox-сканнерам и используется для трекинга, какая жертва кликнула.

5. Цепочка атаки

1. Компрометация почтового ящика aissata-keltoum.drame@psl.eu (вектор не известен; вероятно, AiTM-фишинг или похищенные ранее реквизиты)
2. Регистрация финального домена dotiojea.ru (2026-03-24) на условную физлицо в R01-RU
3. Создание landing-страницы amendment-gateway.lovable.app в no-code сборщике Lovable (бесплатный TLS, Cloudflare-фронт)
4. Отправка письма-приманки 2026-04-15 16:27 UTC через настоящий M365 outbound тенанта PSL — DKIM/SPF/DMARC проходят
5. Получатель кликает CTA → Google click-tracker → amendment-gateway.lovable.app
6. На landing-странице кнопка «View Proposal» → переход на dotiojea.ru/{per-victim-token}/
7. Жертва вводит учётные данные (на момент анализа форма недоступна; по шаблону — M365/DocuSign/Adobe Sign)
8. После компрометации — lateral phishing внутри академической сети, доступ к OneDrive / SharePoint, потенциально BEC

6. Индикаторы компрометации (IOC)

Тип	Значение
Тема письма	2026 Amend Proposal YF-W-SW89537
Compromised sender	aissata-keltoum.drame@psl[.]eu
Tenant ID (M365 PSL)	4f8fd695-b3b5-4082-8005-610e9453e6d0
Outbound MX (M365 FR)	PR0P264CU014.outbound.protection.outlook.com (2a01:111:f403:c20a::4)
EML SHA-256	2d0536dfbbce46c92f588a97da471322bf501111a3 eb04d835ffe8e3b84fb70d
Landing URL	hxxps://amendment-gateway[.]lovable[.]app/
Lovable project ID	bb952617-8387-4712-a353-768d866d428a
Landing IP	185[.]41[.]148[.]1, 185[.]41[.]148[.]2 (AS13335 Cloudflare)
Landing JS SHA-256	6462db810635dcd49271a491e49af9b481b8acc13 be3562341abda7b377200b8
Final URL #1	hxxps://dotiojea[.]ru/ojEyxTnj@JqGnH/
Final URL #2 (related)	hxxps://dotiojea[.]ru/z58!zTjKI/
Final domain	dotiojea[.]ru (R01-RU, 2026-03-24, UNVERIFIED)
Final NS	a.dnspod.com, c.dnspod.com

7. MITRE ATT&CK

ID	Техника
T1583.001	Acquire Infrastructure: Domains (dotiojea.ru, R01-RU)
T1583.006	Acquire Infrastructure: Web Services (Lovable.app project, бесплатный TLS)
T1586.002	Compromise Accounts: Email Accounts (M365 PSL)
T1078.004	Valid Accounts: Cloud Accounts (использование легитимного psl.eu для отправки)
T1566.002	Phishing: Spearphishing Link (CTA «Access File»)
T1564.011	Hide Artifacts: Hidden URLs (per-victim path token)
T1539	Steal Web Session Cookie (предположительно — финальный harvester)

T1606

Forge Web Credentials (предположительно —
AiTM-кит)

8. Рекомендации

8.1. Для PSL (Université Paris Sciences & Lettres)

- Сбросить пароль и отозвать все refresh/access-токены аккаунта aissata-keltoum.drame@psl.eu
- Проверить inbox rules / forwarding / OAuth-grants — типовые follow-up действия атакующего после AiTM
- Поднять политику DMARC домена psl.eu до p=quarantine или p=reject (текущая p=NONE недостаточна)
- В Entra ID sign-in logs — искать нетипичные геолокации, успешные MFA pass-through, новые app-passwords
- Уведомить CERT-RENATER (cert@renater.fr)

8.2. Для получателей (Google Workspace)

- В Email log search — найти всех получателей по subject «2026 Amend Proposal YF-W-» и Message-ID PASP264MB5677...
- Заблокировать в SPAM-фильтре domains: amendment-gateway.lovable.app, dotiojea.ru
- Проверить Workspace audit logs (Gmail/Drive) на аномальные доступы 2026-04-15 → 2026-04-22 у тех же пользователей

8.3. Стратегические

- Abuse-репорт в Lovable.app (abuse@lovable.dev), указать project ID bb952617-8387-4712-a353-768d866d428a
- Abuse в R01-RU (https://partner.r01.ru/contact_admin.khtml) и в КЦ (abuse@cctld.ru) — домен в статусе UNVERIFIED
- Рассмотреть добавление *.lovable.app в URL-категории «no-code site builders» на корпоративных прокси с повышенным contentadult-rating

TLP:CLEAR — Этот документ может распространяться без ограничений.